

AI-SA-IN-TH-000014

Module 8.1 · LLM Evaluation Fundamentals · AI Safety: Evaluation, Guardrails & Responsible Deployment

Data Privacy and Governance

Differential Privacy, Federated Learning, GDPR, CCPA, and Data Governance Frameworks

9 min

Duration

B3 – Apply

Bloom's

L3 – Advanced

Level

Theory

Domain

Learning Objectives

- 1 Explain four privacy threat vectors specific to AI systems and distinguish them from traditional data privacy risks
- 2 Define differential privacy formally and interpret the privacy budget parameter ϵ
- 3 Describe the federated learning architecture and explain how it reduces centralised data collection risk
- 4 Identify which GDPR articles create obligations for organisations deploying AI systems
- 5 Compare GDPR and CCPA rights frameworks and identify which applies in a given deployment context
- 6 Design a data governance framework for an LLM deployment including policies, roles, and lineage tracking

Why Data Privacy Matters Differently for AI

AI-Specific Privacy Risks

Traditional data privacy protects stored data. AI introduces additional privacy risks that are unique: models trained on private data can memorise and later regurgitate that data; model outputs can leak information about training individuals; and even published model weights can be attacked to extract private training data.

- Traditional privacy risk: data breach — an attacker steals stored records from a database
- AI privacy risk 1 — Memorisation: the model itself stores statistical memories of training data that can be extracted via carefully crafted prompts
- AI privacy risk 2 — Membership inference: an attacker can determine whether a specific person's data was in the training set by querying the model's confidence
- AI privacy risk 3 — Model inversion: an attacker reconstructs private training examples from the model's outputs
- AI privacy risk 4 — Unintended disclosure: the model reveals private information in context window, retrieval, or fine-tuning data in its outputs

Four Privacy Threat Vectors in AI Systems

Training Data Memorisation

Model memorises verbatim training data
→ extracted via prompts
Example: GPT extracting real email addresses

Membership Inference Attack

Attacker queries model to detect if individual's data was in training set
→ privacy violation even if no data stolen

Model Inversion Attack

Reconstruct sensitive training examples from model's gradient or output — e.g. recover medical images from MRI AI

Context Window Leakage

Model reveals other users' data from shared context, RAG corpus, or fine-tuning data in multi-tenant deployment

All four vectors require different mitigations: differential privacy (memorisation), adversarial training (inference/inversion), access control (leakage).

Differential Privacy — Formal Definition

Differential Privacy (Dwork & Roth, 2014)

A mathematical framework that provides a formal privacy guarantee: a randomised mechanism M is ϵ -differentially private if its output distribution is nearly identical whether or not any single individual's data is included in the dataset — making it impossible for an adversary to determine with confidence whether any specific person's data was used in training.

- Formal: mechanism M is (ϵ, δ) -DP if for all datasets D, D' differing in one row: $P[M(D) \in S] \leq e^\epsilon \cdot P[M(D') \in S] + \delta$
- ϵ (epsilon): the privacy budget — lower ϵ = stronger privacy guarantee; $\epsilon=0$ means the mechanism is perfectly private; $\epsilon=10$ means very weak privacy
- δ (delta): a small probability of failure; typically set to $1/(n^2)$ where n is dataset size; often $\delta=10^{-5}$
- Implementation: add calibrated random noise (Gaussian or Laplace) to model gradients during training — DP-SGD (Abadi et al., 2016)
- Apple iOS uses $\epsilon=1-8$ for on-device telemetry; Google uses $\epsilon=0.01$ for Chrome browsing histograms
- Tradeoff: adding noise degrades model utility — the accuracy cost depends on dataset size (larger dataset = smaller privacy-utility tradeoff)

Privacy Budget (ϵ) — Worked Calculation

$$\text{Laplace Noise Scale} = \text{Sensitivity} / \epsilon \quad (\text{for counting queries})$$

1. Task: count how many users in a hospital dataset have diabetes — true count = 847
2. Sensitivity: adding/removing one person changes count by at most 1 $\rightarrow$ sensitivity = 1
3. Target privacy budget: $\epsilon = 1.0$ (moderate privacy)
4. Laplace noise scale = $1 / 1.0 = 1.0 \rightarrow$ add Laplace(0, 1.0) noise
5. Private count = $847 + \text{Laplace}(0, 1.0) \approx 847 \pm 2$ (95% of the time within ± 2) — very accurate
6. Stronger privacy ($\epsilon=0.1$): Laplace(0, 10) noise $\rightarrow$ private count $\approx 847 \pm 20$ — 5 $\times$ more private, 10 $\times$ less accurate

Note: Privacy-utility tradeoff scales inversely with ϵ . For training deep learning models, ϵ values of 3–10 are typical in industry; below $\epsilon=1$ usually causes significant accuracy degradation.

Federated Learning — Privacy-Preserving Training

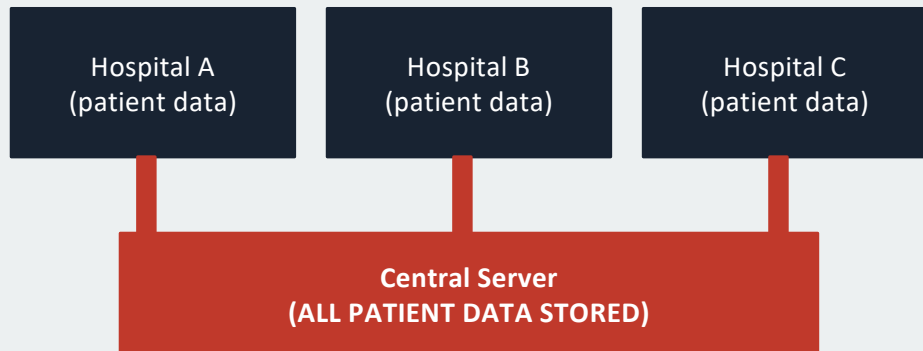
Federated Learning (McMahan et al., Google, 2017)

A machine learning paradigm where training occurs on devices or servers that own the data — data never leaves its source. Only model updates (gradients) are sent to a central server for aggregation, never the raw training data itself.

- Architecture: central server sends model weights to N clients; each client trains locally on private data; clients send only gradient updates back; server aggregates updates (FedAvg)
- Privacy benefit: raw data never leaves client devices — eliminates centralised data collection risk
- Applications: Google Keyboard next-word prediction trained on phone text without seeing messages; medical AI trained across hospitals without sharing patient records
- Limitations: gradient updates can leak information via gradient inversion attacks — combine with differential privacy for strong guarantees
- Communication cost: gradient updates are large — compression (FedProx, SCAFFOLD) needed for bandwidth-constrained deployments
- Regulatory benefit: federated training across EU jurisdictions avoids GDPR data transfer restrictions

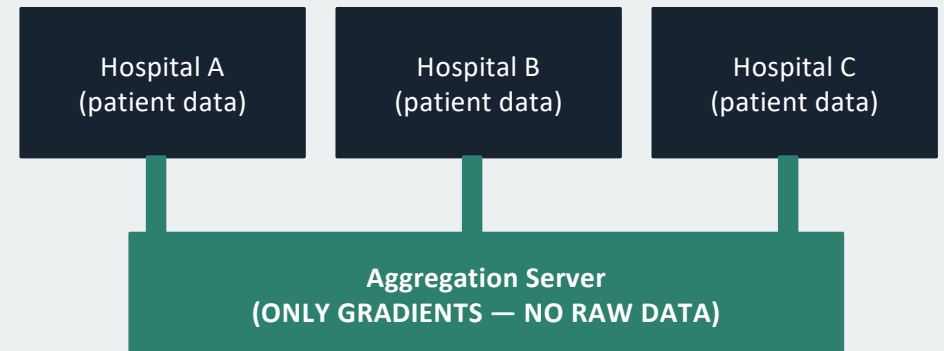
Federated vs Centralised Training Architecture

Centralised Training (Privacy Risk)



⚠ Data breach risk ⚠ GDPR cross-border transfer ⚠ Centralised vulnerability

Federated Learning (Privacy-Preserving)



✓ No raw data transfer ✓ GDPR compliant ✓ Distributed resilience

GDPR Key Articles for AI Systems

Article	Title	AI Obligation
Art 5	Principles of data processing	Data minimisation (only collect what's needed); purpose limitation (only use for stated purpose); accuracy (training data must be accurate)
Art 13/14	Transparency information	Users must be informed if their data is used to train AI; automated decision-making must be disclosed
Art 17	Right to erasure ('right to be forgotten')	If a user requests erasure, their training data must be removed — but removing influence from a trained model is an unsolved technical problem (machine unlearning)
Art 22	Automated decision-making	Right not to be subject to fully automated decisions with significant effects; right to human review and explanation
Art 35	Data Protection Impact Assessment (DPIA)	Required before deploying AI systems that process personal data at scale or in high-risk contexts
Art 83	Fines	Up to €20M or 4% global turnover for Articles 5/13/14/17; up to €10M or 2% for Art 22/35

GDPR vs CCPA — Rights Comparison

GDPR (EU, 2018)

- Jurisdiction: applies to all organisations processing EU residents' personal data — regardless of where organisation is located
- Lawful basis: must have legal basis (consent, contract, legitimate interest, etc.) for every processing activity
- Right to access: users can request copy of all personal data held
- Right to erasure: 'right to be forgotten' — applies to training data
- Right to explanation: Art 22 mandates human review and explanation for automated decisions
- Enforcement: national data protection authorities; fines up to €20M / 4% global turnover

CCPA (California, 2020)

- Jurisdiction: applies to for-profit businesses above revenue/data thresholds serving California residents
- Opt-out focused: no requirement to have lawful basis; users can opt out of sale/sharing of personal data
- Right to know: what data is collected, sources, uses, third-party recipients
- Right to delete: narrower than GDPR erasure — several business-need exceptions
- No right to explanation: no explicit right to explanation for automated decisions (as of 2025)
- Enforcement: California Attorney General; fines up to \$7,500 per intentional violation

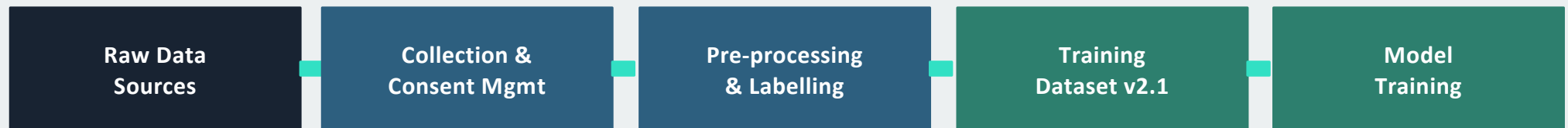
Data Governance Framework for AI

Data Governance Framework

The set of policies, processes, roles, and standards that govern how data is collected, stored, processed, and used throughout an AI system's lifecycle — ensuring data quality, privacy compliance, security, and auditability.

- Policies: data retention policy (how long is data kept); consent policy (how is user permission obtained); access policy (who can see training data); deletion policy (how erasure requests are fulfilled)
- Roles: Data Protection Officer (DPO — required under GDPR for high-risk processing); Data Steward (day-to-day data quality); Data Owner (accountability for a dataset)
- Processes: Data Protection Impact Assessment before deployment; periodic data audits; breach notification process (GDPR: 72-hour notification to regulator)
- Standards: data classification (public/internal/confidential/restricted); data format standards for training datasets; anonymisation standards
- Technical controls: access control and logging; encryption at rest and in transit; differential privacy in training; model auditing and versioning

Data Lineage and Provenance Pipeline



Lineage Record (logged at every stage):

```
{"stage": "pre-processing", "ts": "2026-01-15T10:32:00Z", "input_hash": "a3f8b2c4",  
  "output_hash": "7d9e1a5b", "operator": "data_team", "consent_verified": true,  
  "pii_removed": true, "records_in": 1450230, "records_out": 1421847,  
  "removal_reason": "pii_detected: 28383 rows"}
```

Lineage records enable GDPR erasure requests: trace exactly which training records contain a user's data and which model version was trained on them.

On-Premise vs Cloud — Privacy Tradeoffs

Dimension	On-Premise	Cloud (API-based)
Data control	Full control — data never leaves your infrastructure	Data processed on provider servers — review DPA carefully
GDPR compliance	Easier — no third-party data transfer	Requires Standard Contractual Clauses (SCCs) or Binding Corporate Rules
Training data security	Physical security under your control	Shared infrastructure — encryption at rest/transit essential
Model extraction risk	Lower — weights stay on-prem	API queries could enable model extraction attacks
Operational cost	High upfront (GPU hardware, MLOps team)	Low upfront, variable — scales with usage
Recommended for	Healthcare, finance, defence, legal data	Low-risk applications, startups, non-PII workloads

Case Study — Samsung ChatGPT Leak + Training Data Privacy Risks

Case: Samsung Semiconductor Engineers Upload Confidential Code to ChatGPT (March 2023)

- Three separate incidents within one month: Samsung engineers pasted proprietary source code into ChatGPT prompts for debugging and documentation assistance
- Incident 1: proprietary chip yield measurement code uploaded; Incident 2: internal meeting notes; Incident 3: full source code of battery measurement tool
- OpenAI's terms of service at the time allowed using API interaction data for model improvement — the proprietary data could potentially become part of future model training
- Samsung had no corporate policy prohibiting the use of generative AI tools or prohibiting submission of confidential data
- Samsung banned all generative AI tool use within the company after discovery — an overly broad response that created productivity losses

Key Lesson

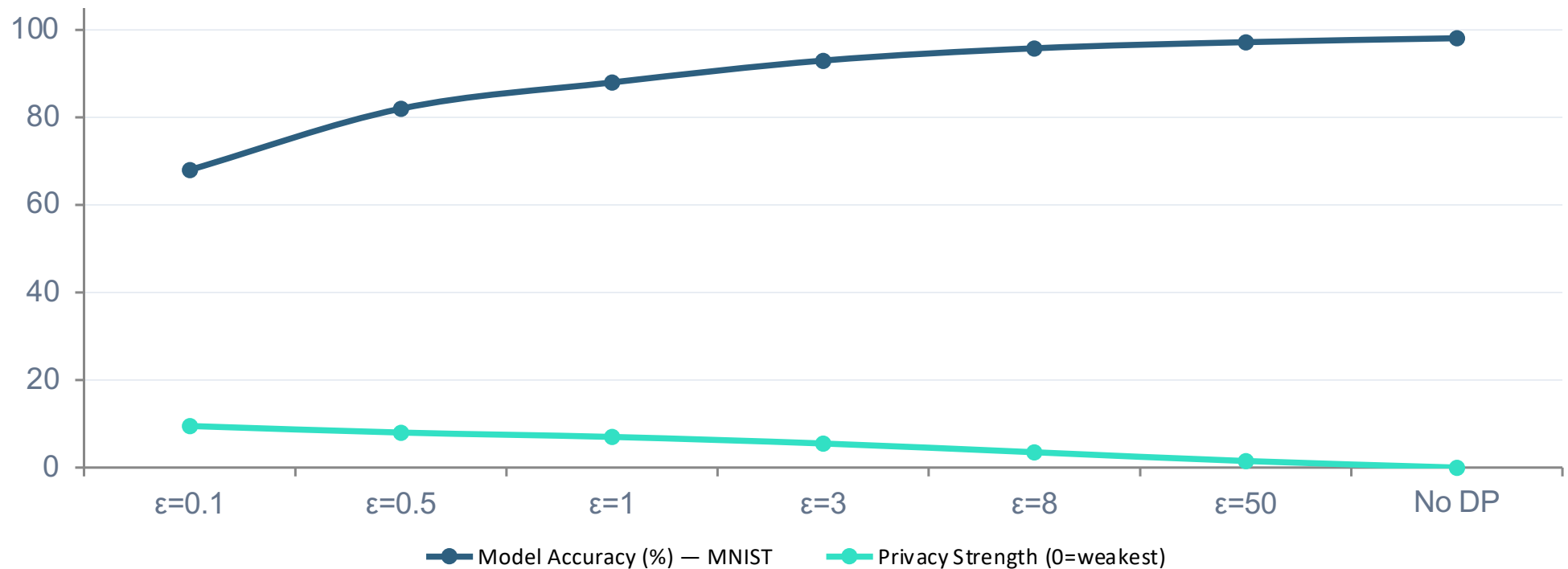
Privacy governance failure: (1) No acceptable use policy for generative AI; (2) No technical controls (DLP tools) blocking confidential data upload; (3) No employee training on data classification. Correct response: implement tiered policy (self-hosted models for confidential data; cloud AI only for public/internal-tier data), deploy DLP controls, and provide role-specific AI usage training.

Data Subject Rights in the AI Context

GDPR data subject rights create specific technical obligations for AI systems:

- Right of access (Art 15): organisations must be able to tell a user exactly what personal data about them was used to train or fine-tune AI models — requires data lineage tracking from raw collection to model version
- Right to erasure (Art 17): if a user requests deletion, their training data must be removed — and ideally, the model's 'memory' of that data too (machine unlearning) — technically unsolved but becoming a regulatory requirement
- Right to rectification (Art 16): if a user's data was labelled incorrectly (e.g. wrong medical diagnosis used as training label), they can request correction — requires ability to identify and update specific training examples
- Right to portability (Art 20): users can request their data in a machine-readable format — AI training pipelines must track individual-level data provenance to fulfill this
- Right to object (Art 21): users can object to their data being used for AI training — organisations must be able to remove objecting users' data from future training runs without disrupting the pipeline
- Right to explanation (Art 22): for fully automated decisions with significant effects, organisations must provide meaningful information about the logic — requires post-hoc explainability built into deployed AI systems

Privacy Budget (ϵ) vs Model Utility Tradeoff



Source: Abadi et al. (2016) DP-SGD paper, MNIST benchmark. At $\epsilon=1$ (strong privacy): ~10pp accuracy cost. At $\epsilon=8$ (moderate): ~2pp cost. Most industry deployments use $\epsilon=3-8$. Strong guarantees ($\epsilon<1$) cause substantial utility degradation for complex tasks.

Key Takeaways

AI-SA-IN-TH-000014

- 1 AI introduces privacy risks beyond traditional data breaches: training data memorisation, membership inference, model inversion, and context window leakage — each requires a different technical mitigation
- 2 Differential privacy adds calibrated noise to training to provide formal mathematical privacy guarantees — the privacy budget ϵ is a tradeoff parameter: lower ϵ = stronger privacy, lower model utility
- 3 Federated learning keeps raw data on client devices, sending only gradient updates — eliminates centralised data collection risk but requires combining with DP to prevent gradient inversion attacks
- 4 GDPR Article 22 requires human review and explanation for automated AI decisions; Article 17 (right to erasure) creates technical obligations for model unlearning — neither can be fulfilled without data lineage tracking
- 5 Data governance is not optional: a written data governance framework (policies, roles, lineage pipeline) is required for GDPR compliance and is the foundation for all other privacy controls